

Le **RGPD** est une loi européenne entrée en vigueur le **25 mai 2018**. Elle protège les **données personnelles** et encadre leur utilisation par les entreprises.

Objectifs du RGPD

- Protéger la vie privée des utilisateurs
- Garantir la transparence des traitements de données
- Donner des droits aux utilisateurs
- Responsabiliser les entreprises

Principe	Explication
Consentement	L'utilisateur doit accepter le traitement de ses données
Finalité	Les données doivent être collectées pour un but précis
Minimisation	On collecte uniquement les données nécessaires
Sécurité	Les données doivent être protégées
Droit d'accès	L'utilisateur peut consulter ses données
Droit à l'oubli	L'utilisateur peut demander la suppression de ses données

Données concernées

- Nom, prénom, email, téléphone
- Adresse IP
- Données bancairesect

Obligations pour un développeur (DWWM)

- Ne pas stocker des données inutiles
- Chiffrer les mots de passe (bcrypt)
- Sécuriser les formulaires
- Prévoir une page **Mentions légales + Confidentialité**
- Obtenir le **consentement cookies**

Sécurité des applications

La sécurité protège l'application contre les attaques. Une application non sécurisée met en danger **les données, les utilisateurs et l'entreprise**.

Menace	Description	Exemple
SQL Injection	Exploitation d'une requête SQL	' OR '1'='1
XSS (Cross-Site Scripting)	Injection de script dans une page	<script>alert('hack')</script>
CSRF	Action malveillante à l'insu de l'utilisateur	Faux formulaire
Brute Force	Test automatique de mots de passe	Attaques login
Fuite de données	Mauvaise gestion des accès	Contrôle d'accès absent

Bonnes pratiques de sécurité

- * Valider et filtrer les entrées utilisateurs
- * Prévenir les injections SQL (requêtes préparées)
- * Hacher les mots de passe (bcrypt)
- * Utiliser HTTPS
- * Gérer les droits utilisateur
- * Mettre à jour les dépendances
- * Activer pare-feu ou protections serveur
- * Sauvegardes régulières + logs

Exemple de question à l'examen DWWM

Q1 : Qu'est-ce que le RGPD ?

→ Réponse courte : *Règlement européen qui protège les données personnelles et impose des règles de collecte, stockage et traitement.*

Q2 : Citez 2 bonnes pratiques pour sécuriser une application web.

→ Exemple : *Validation des entrées + hachage des mots de passe.*

Q3 : Qu'est-ce qu'une injection SQL ?

→ *Attaque qui modifie une requête SQL via un champ non sécurisé.*

Q4 : Que dit le RGPD sur les droits des utilisateurs ?

→ *Ils ont droit d'accès, droit de rectification, droit à l'oubli, droit d'opposition.*